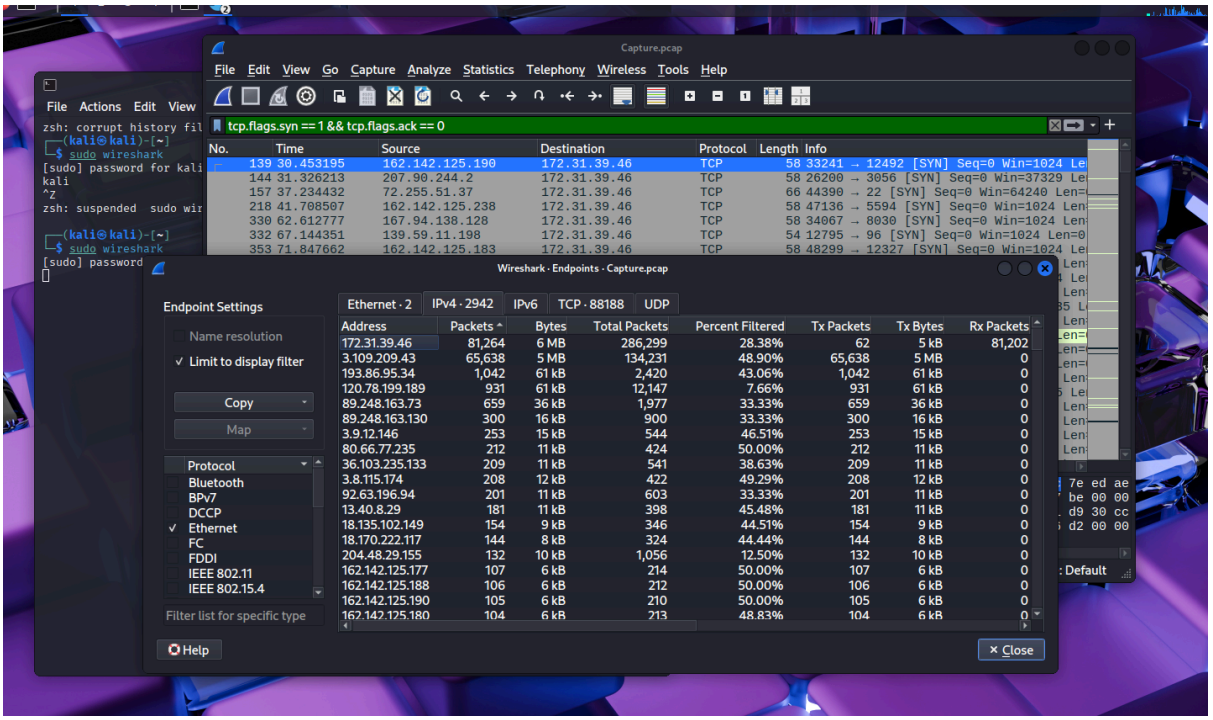
LAB2-CONTINUED OF LAB1

Computer Forensics – Lab 1

ILGIN CEYLAN
82862

TASK-1

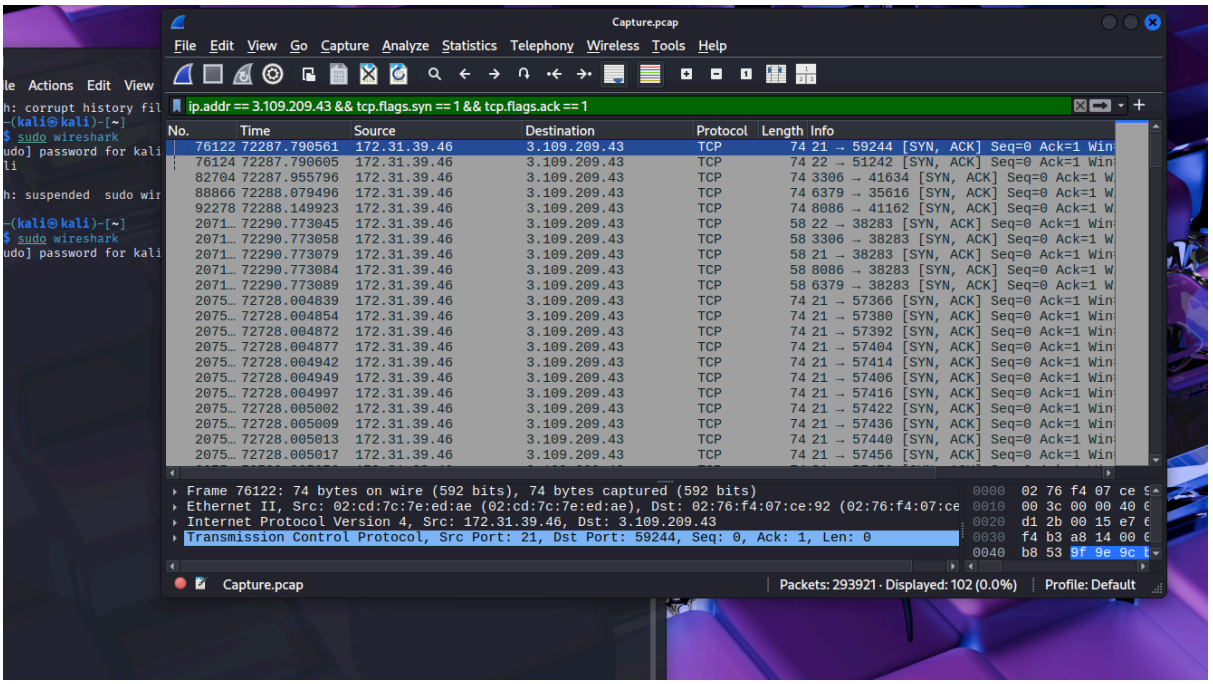


I opened Capture.pcap in Wireshark and applied the filter `tcp.flags.syn == 1 && tcp.flags.ack == 0`. Then I went to Statistics → Endpoints → IPv4 and ticked “Limit to display filter”. Sorting by Tx Packets shows one clear leader: *3.109.209.43* with 65,638 SYN packets, all sent to 172.31.39.46 on many different ports. The other external IPs sent only a few hundred or thousand packets, which looks like normal internet background scanning.

Answer: 3.109.209.43

Why `syn == 1 && ack == 0` and not just `syn == 1`? If I only filter on SYN, the server’s SYN-ACK replies also match, because they carry the SYN flag too. Adding `ack == 0` keeps only the first packet of a handshake, which is the one the client sends. So I only see the packets that the scanner started.

TASK-2

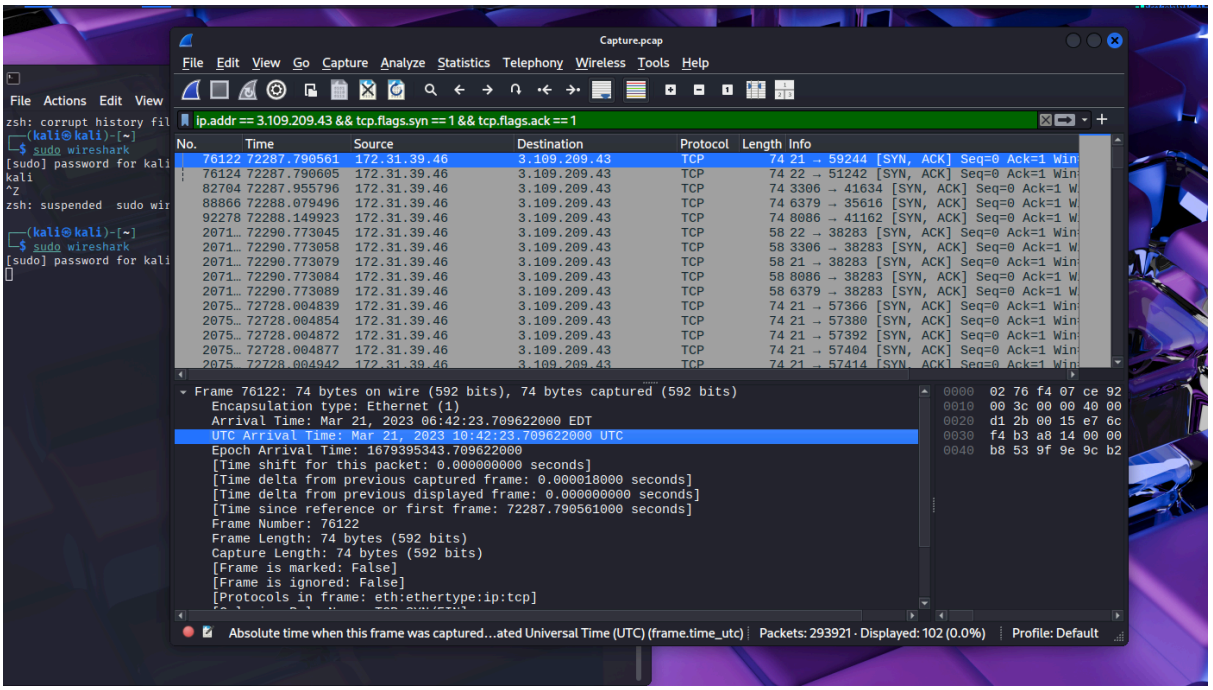


I used ***ip.addr == 3.109.209.43 && tcp.flags.syn == 1 && tcp.flags.ack == 1***. These are the server's replies to the scan. A reply with SYN and ACK means the port accepted the connection. The source ports in these replies are the open ports.

Answer: 21, 22, 3306, 6379, 8086

Why SYN+ACK and not just ACK? The ACK flag is set in almost every packet after the first one, including normal data and RST,ACK replies from closed ports, so it doesn't prove anything on its own. Only an open port answers a SYN with SYN+ACK. Closed ports answer with RST.

TASK-3

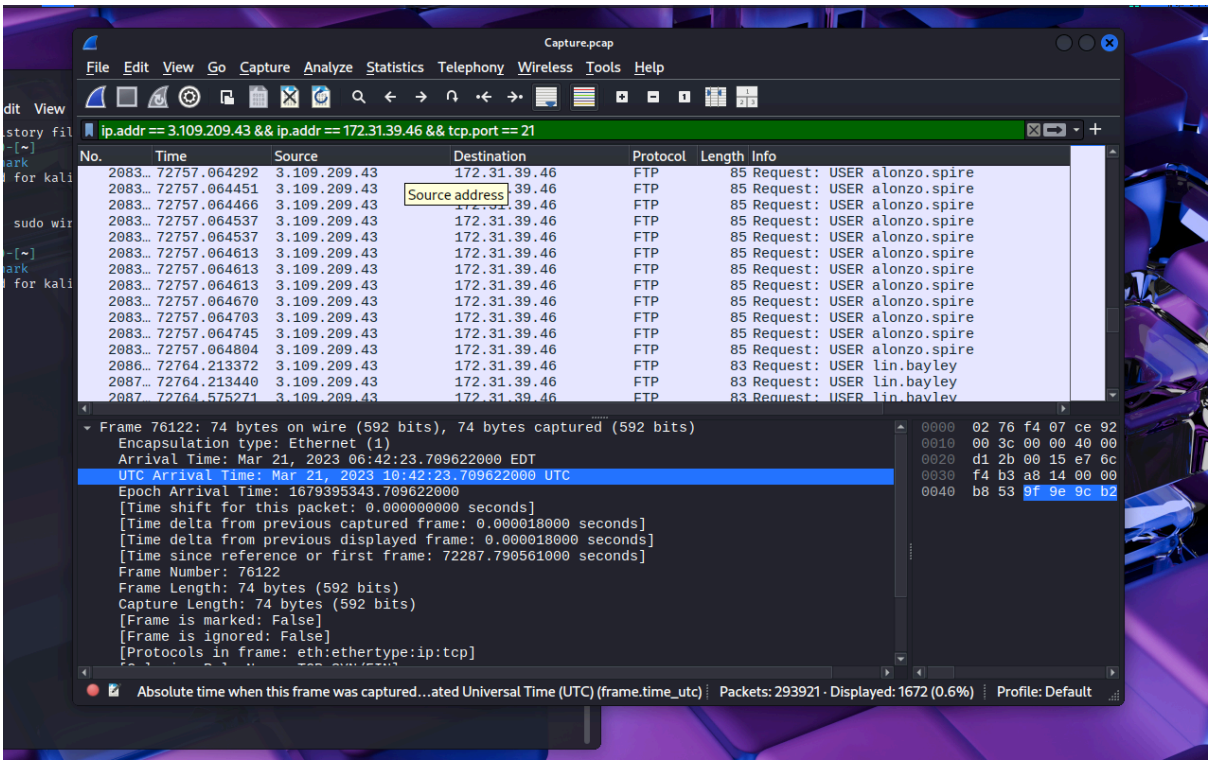


I selected the first packet of the exchange between 3.109.209.43 and the server (frame 76122, the server's SYN-ACK reply to the scanner's first SYN) and expanded the Frame section in Packet Details to read the UTC Arrival Time. The Frame details show that the previous captured packet arrived only 0.000018 seconds earlier, so the scan started within the same second.

Answer: 2023-03-21 10:42:23 UTC

How did I identify this packet? It is the first packet in the traffic between 3.109.209.43 and the server. It is a SYN-ACK reply from the server to a SYN sent by the scanner, and it is followed right away by replies to SYN packets sent to many other ports in a very short time. Normal traffic usually goes to one service port and completes a full handshake, while this one touched many ports without finishing connections, which is typical for a port scan.

TASK-4

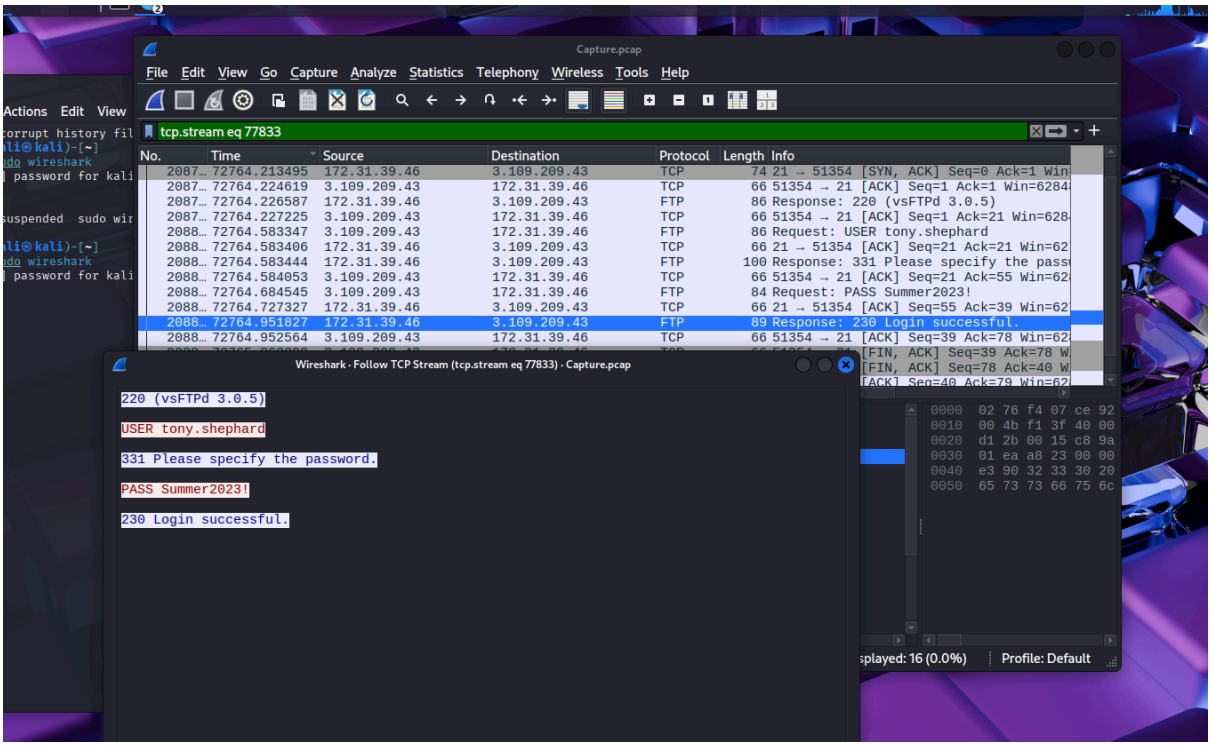


On port 21 I saw the attacker trying many different usernames *(for example tony.shephard, lin.bayley and alonzo.spire)* with the same few passwords, like *Summer2023!*. They did not try thousands of passwords on one account. This matches Password Spraying.

Answer: T1110.003 (Brute Force: Password Spraying)

Why were USER and PASS visible in plain text? FTP has no encryption. Commands and responses travel as normal text, so anyone who captures the traffic can read the credentials. SFTP or FTPS should be used instead.

TASK-5

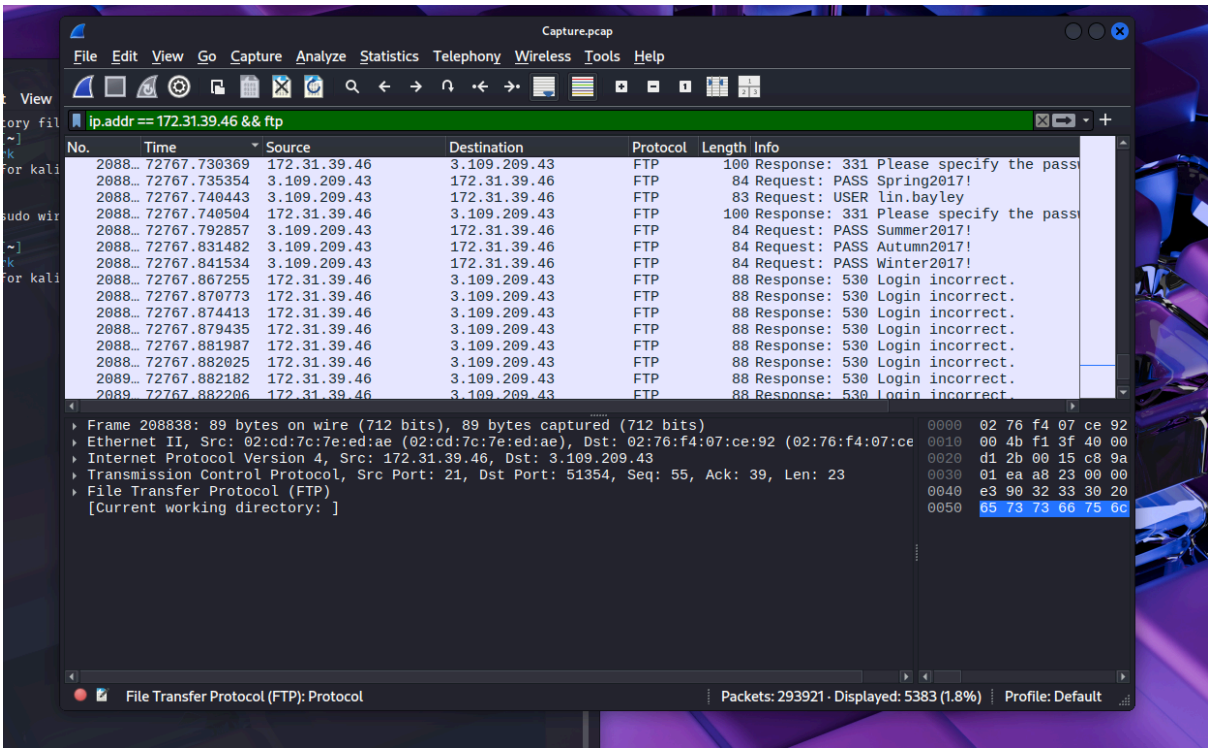


I filtered with `ftp.response.code == 230`, picked the successful login, and used Follow → TCP Stream. The stream shows *USER tony.shephard* and *PASS Summer2023!* followed by “230 Login successful”.

Answer: tony.shephard : Summer2023!

Why is this Initial Access and not Reconnaissance? Reconnaissance only collects information. Here the attacker actually logged in with a valid account, so they had a real foothold on the server. With an FTP account they can list and download files, read configuration files and stored credentials, and upload files if write permission exists.

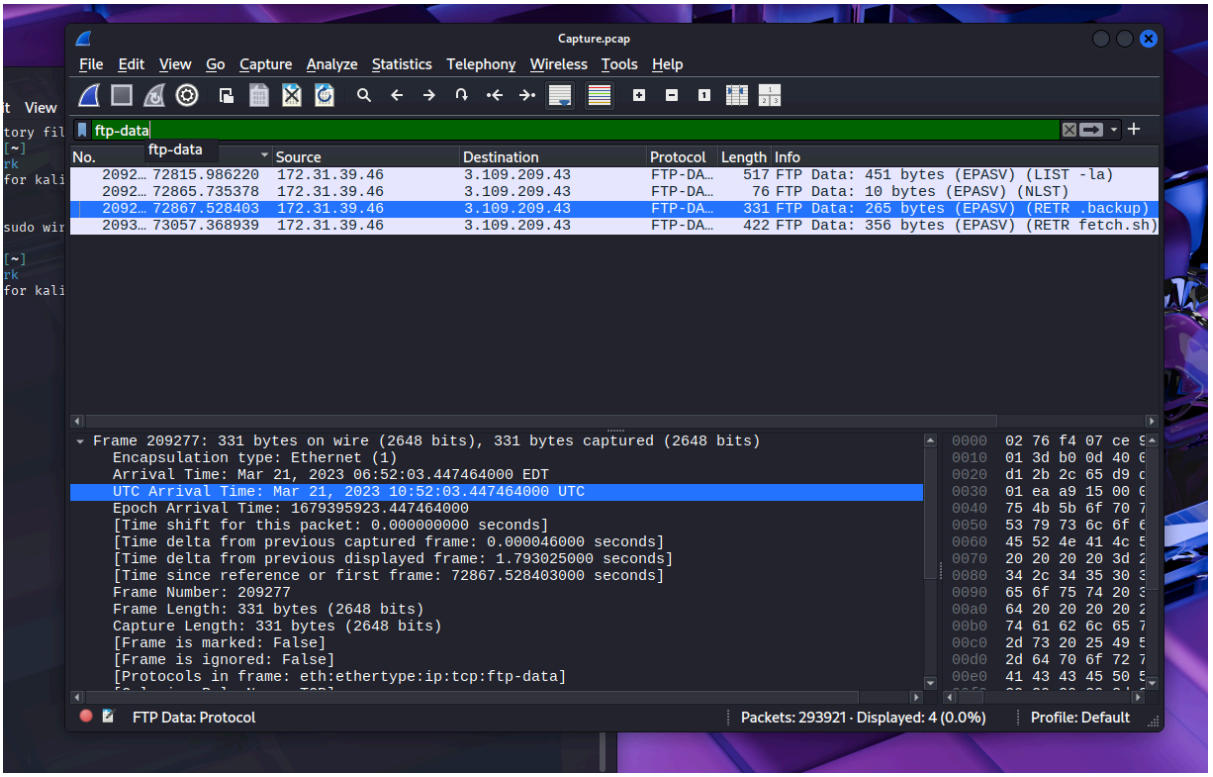
TASK-6

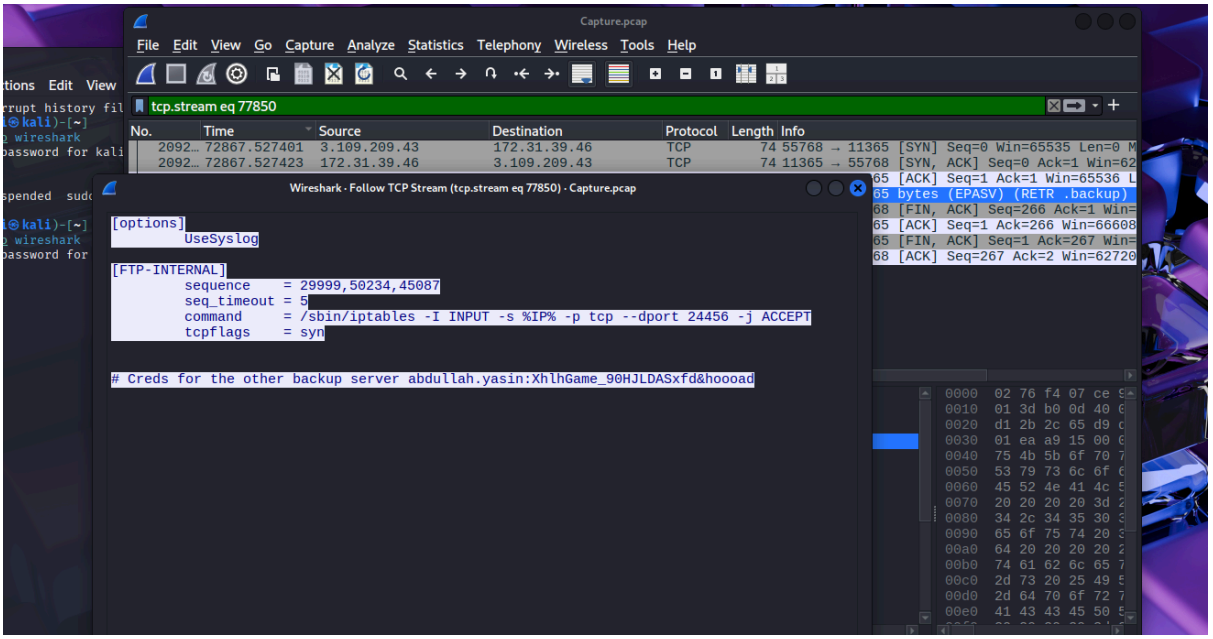


The external IP talking to the FTP service, including the failed "*530 Login incorrect*" attempts, is the same scanner IP.

Answer: 3.109.209.43

TASK-7



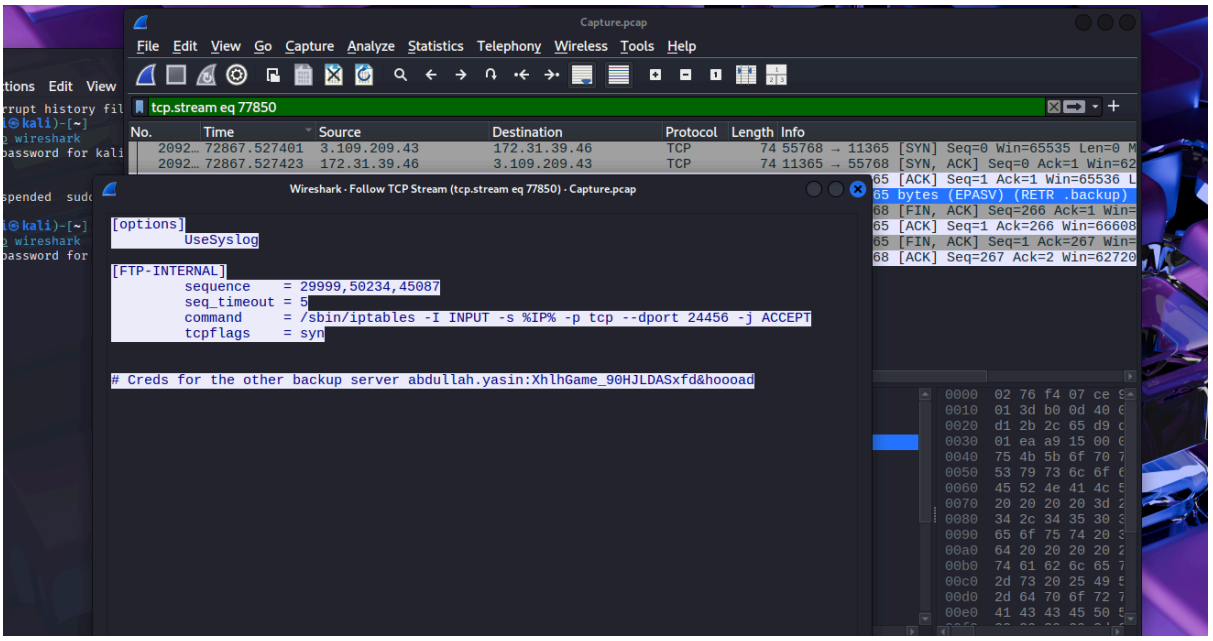


With the filter *ftp-data* I found two RETR commands, *fetch.sh* and *.backup*. Following the TCP stream of *.backup* showed a knockd configuration and a comment line with credentials for another backup server.

Answer: .backup

Why does it contain a knockd configuration, and how does port knocking work? knockd is the daemon that implements port knocking on the server, so the admin kept its config in a backup file. Port knocking keeps a service port closed in the firewall until a client sends connection attempts to a secret sequence of ports in the right order. After that, the firewall opens the real port for that IP. It is used to hide services from scanners.

TASK-8

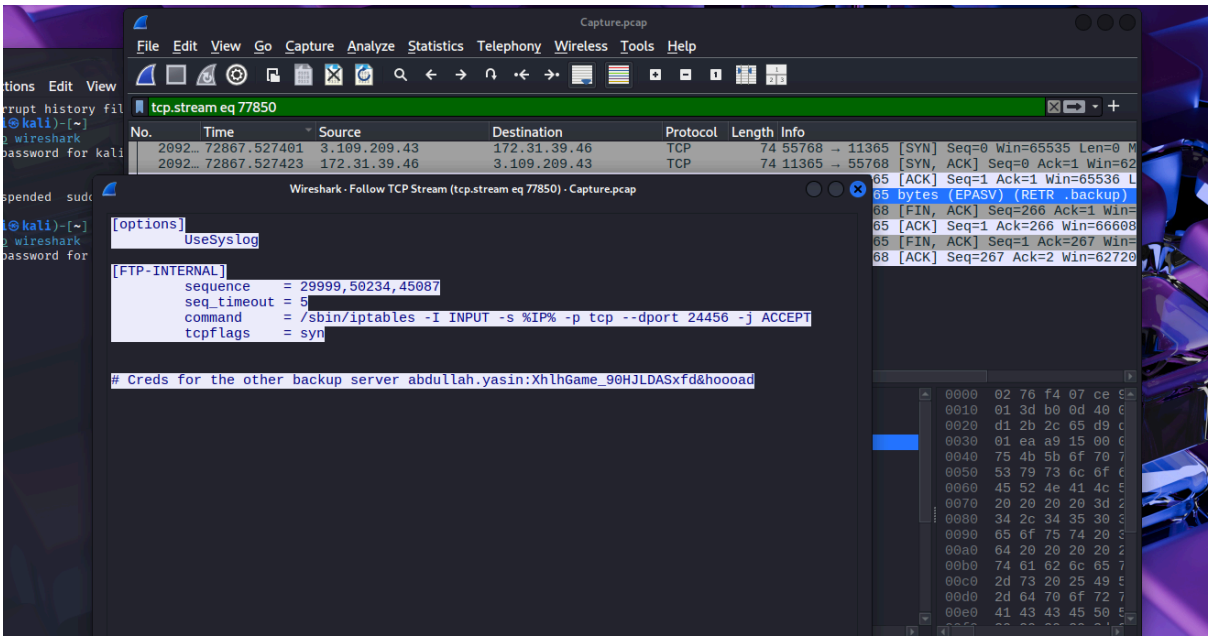


In the `.backup` stream, the iptables command in the config uses `--dport 24456`.

Answer: 24456

Formal name of this defence technique: Port knocking (it is a form of security through obscurity).

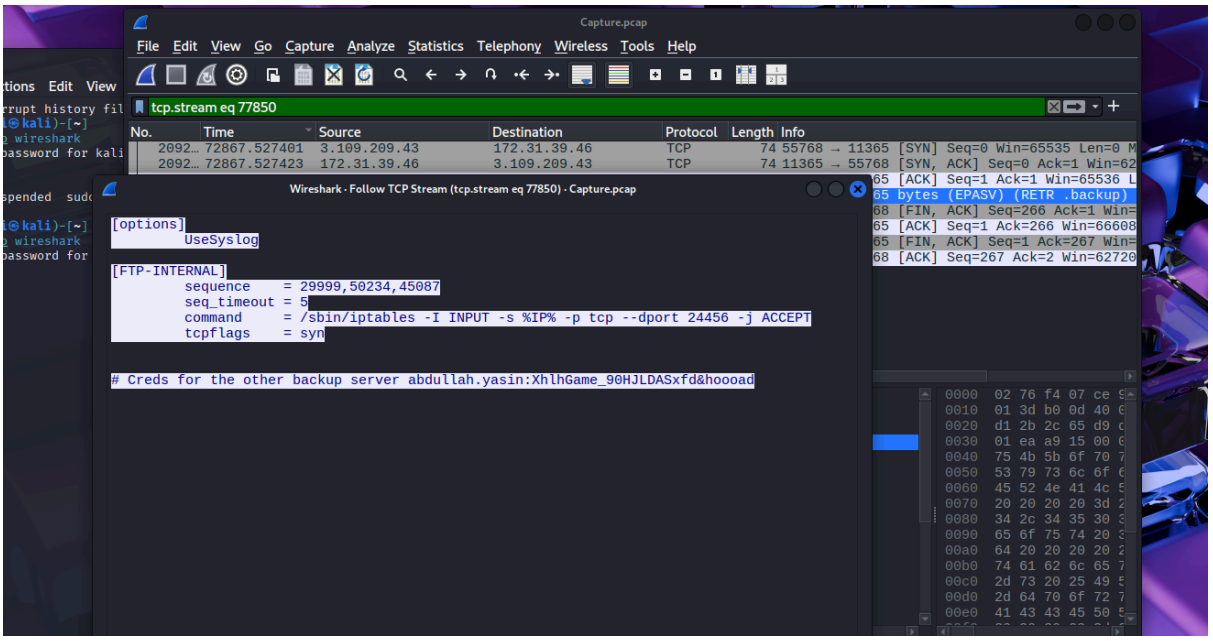
TASK-9



Answer: Port knocking

How does it work and how does an attacker open a closed port? The firewall keeps port 24456 closed by default. knockd watches for connection attempts. If a client sends SYN packets to the configured ports in the correct order within the timeout (5 seconds here), knockd runs the iptables rule that opens the target port for that client's IP. The attacker got the sequence from the stolen ***.backup*** file, so they could repeat it and open the port.

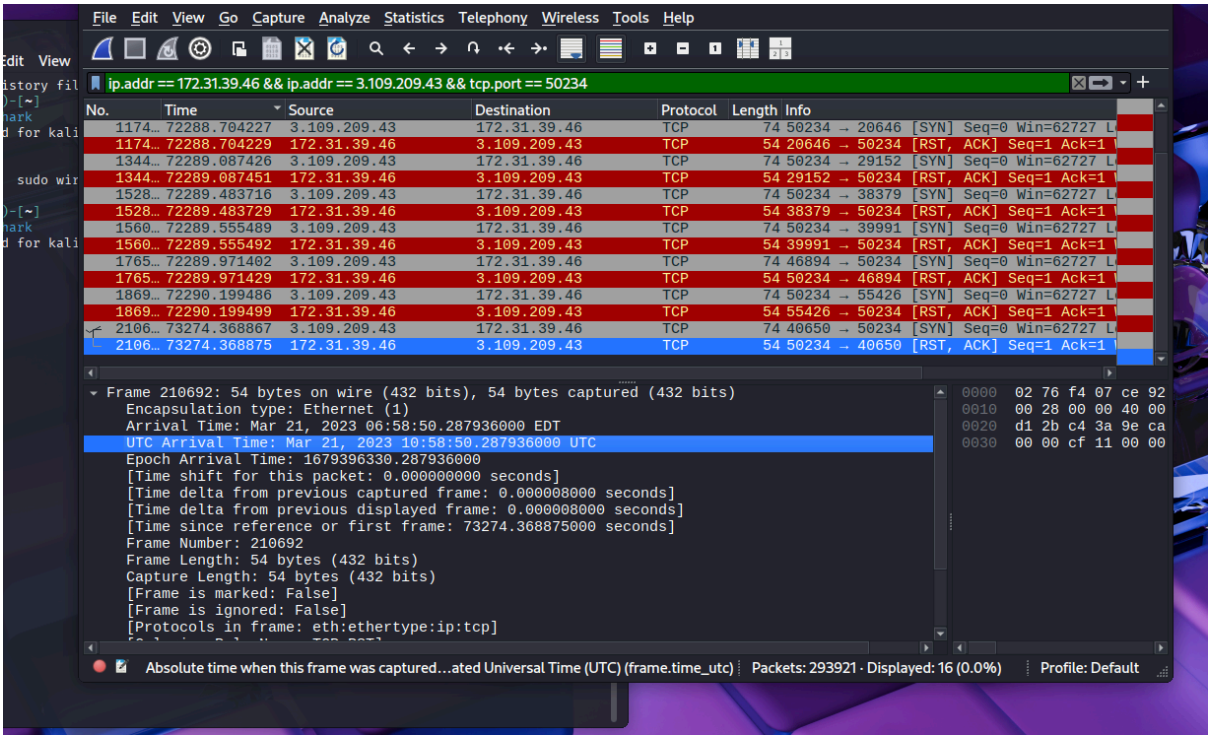
TASK-10



Answer: 29999, 50234, 45087

Same protocol? Yes, all TCP. The config has *`tcpflags = syn`*, so a SYN packet to each port is enough.

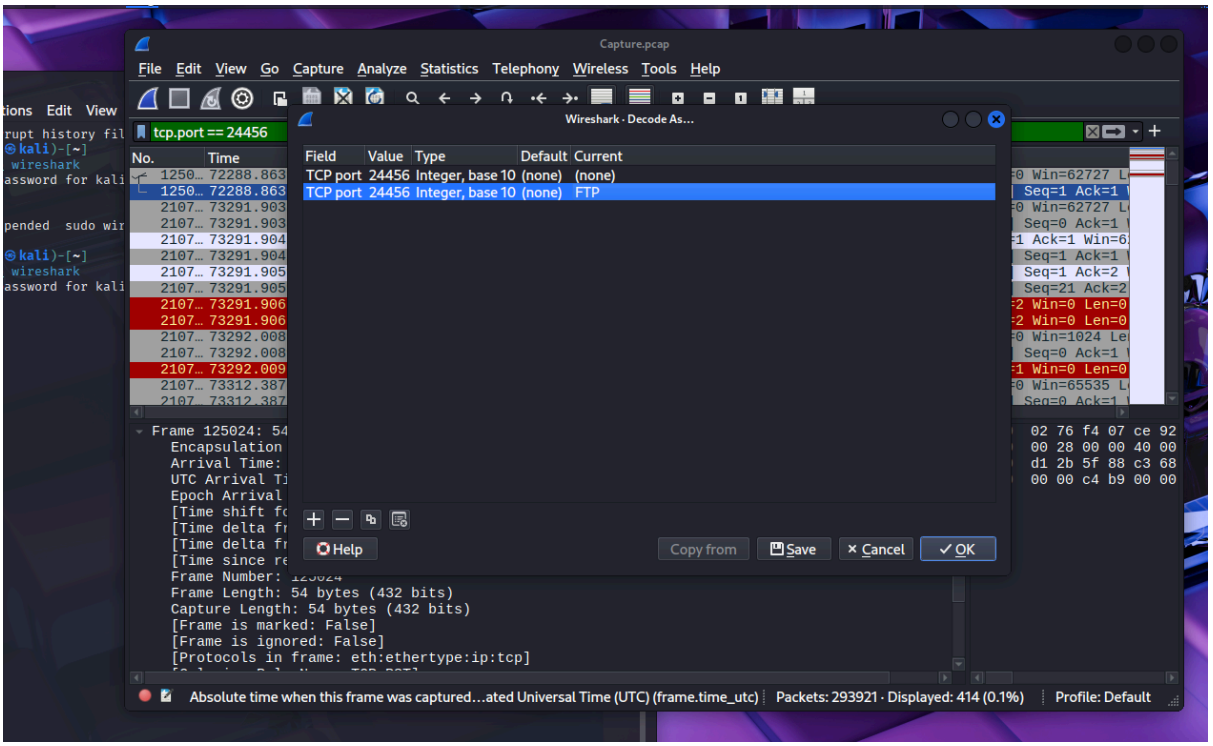
TASK-11

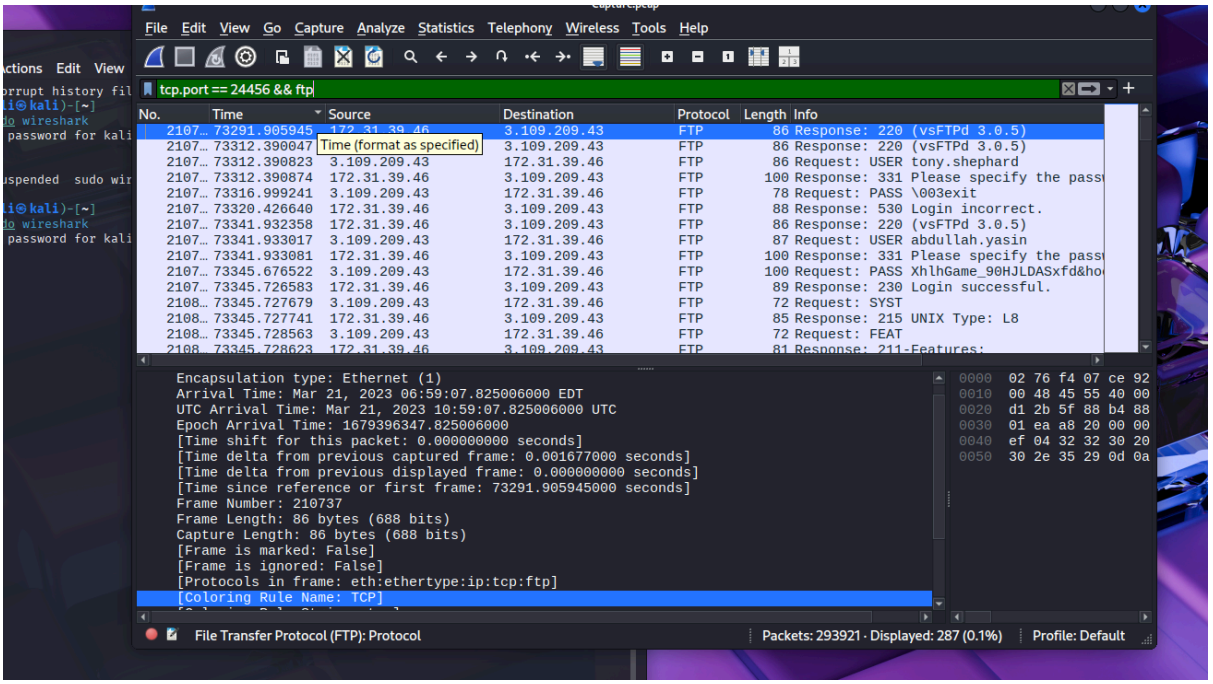


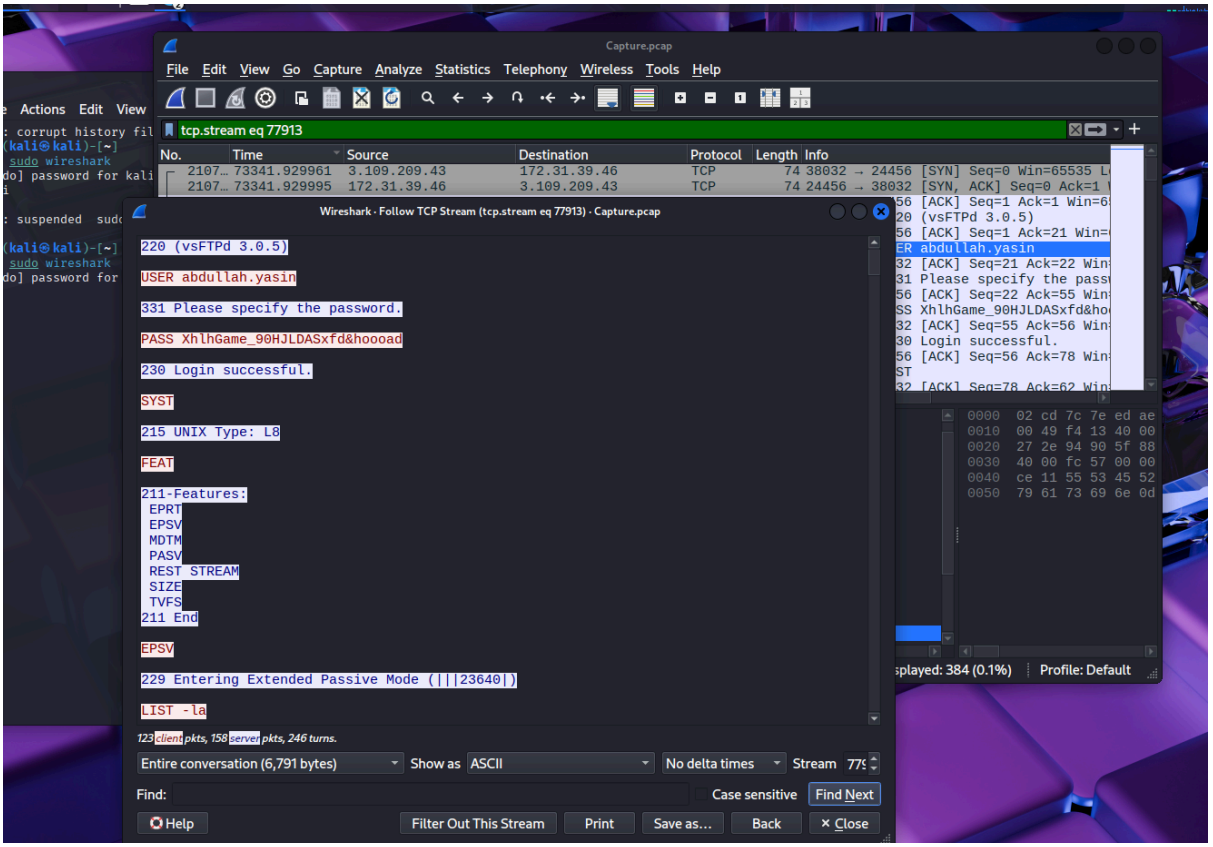
I applied the filter *ip.addr == 172.31.39.46 && ip.addr == 3.109.209.43 && tcp.port == 50234* to see the traffic between the attacker and the server on the knocking port. The last packet in the list is frame 210692, the server's RST, ACK reply to the attacker's last SYN (source port 40650 to port 50234). The earlier packets in the list, where 50234 is the attacker's source port, belong to the scan phase. In Packet Details, under the Frame section, the UTC Arrival Time of this packet is Mar 21, 2023 10:58:50.287936 UTC. The "Arrival Time" line above it shows EDT, which is only my VM's local time zone, so I used the UTC line.

Answer: 2023-03-21 10:58:50 UTC

TASK-12


Capture.pcap
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
tcp.port == 24456
Wireshark · Decode As...
Field Value Type Default Current
TCP port 24456 Integer, base 10 (none) (none)
TCP port 24456 Integer, base 10 (none) FTP
Help
Copy from
Save
Cancel
OK
Absolute time when this frame was captured...ated Universal Time (UTC) (frame.time_utc)
Packets: 293921 · Displayed: 414 (0.1%)
Profile: Default


File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
tcp.port == 24456 && ftp
No. Time Source Destination Protocol Length Info
2107... 73291.905945 172.31.39.46 3.109.209.43 FTP 86 Response: 220 (vsFTPd 3.0.5)
2107... 73312.390047 Time (format as specified) 3.109.209.43 FTP 86 Response: 220 (vsFTPd 3.0.5)
2107... 73312.390823 3.109.209.43 172.31.39.46 FTP 86 Request: USER tony.shephard
2107... 73312.390874 172.31.39.46 3.109.209.43 FTP 100 Response: 331 Please specify the pass
2107... 73316.999241 3.109.209.43 172.31.39.46 FTP 78 Request: PASS \003exit
2107... 73320.426640 172.31.39.46 3.109.209.43 FTP 88 Response: 530 Login incorrect.
2107... 73341.932358 172.31.39.46 3.109.209.43 FTP 86 Response: 220 (vsFTPd 3.0.5)
2107... 73341.933017 3.109.209.43 172.31.39.46 FTP 87 Request: USER abdullah.yasin
2107... 73341.933081 172.31.39.46 3.109.209.43 FTP 100 Response: 331 Please specify the pass
2107... 73345.676522 3.109.209.43 172.31.39.46 FTP 100 Request: PASS XhlhGame_90HJLDASxfd&ho
2107... 73345.726583 172.31.39.46 3.109.209.43 FTP 89 Response: 230 Login successful.
2108... 73345.727679 3.109.209.43 172.31.39.46 FTP 72 Request: SYST
2108... 73345.727741 172.31.39.46 3.109.209.43 FTP 85 Response: 215 UNIX Type: L8
2108... 73345.728563 3.109.209.43 172.31.39.46 FTP 72 Request: FEAT
Encapsulation type: Ethernet (1)
Arrival Time: Mar 21, 2023 06:59:07.825006000 EDT
UTC Arrival Time: Mar 21, 2023 10:59:07.825006000 UTC
Epoch Arrival Time: 1679396347.825006000
[Time shift for this packet: 0.000000000 seconds]
[Time delta from previous captured frame: 0.001677000 seconds]
[Time delta from previous displayed frame: 0.000000000 seconds]
[Time since reference or first frame: 73291.905945000 seconds]
Frame Number: 210737
Frame Length: 86 bytes (688 bits)
Capture Length: 86 bytes (688 bits)
[Frame is marked: False]
[Frame is ignored: False]
[Protocols in frame: eth:ethertype:ip:tcp:ftp]
[Coloring Rule Name: TCP]
File Transfer Protocol (FTP): Protocol
Packets: 293921 · Displayed: 287 (0.1%)
Profile: Default

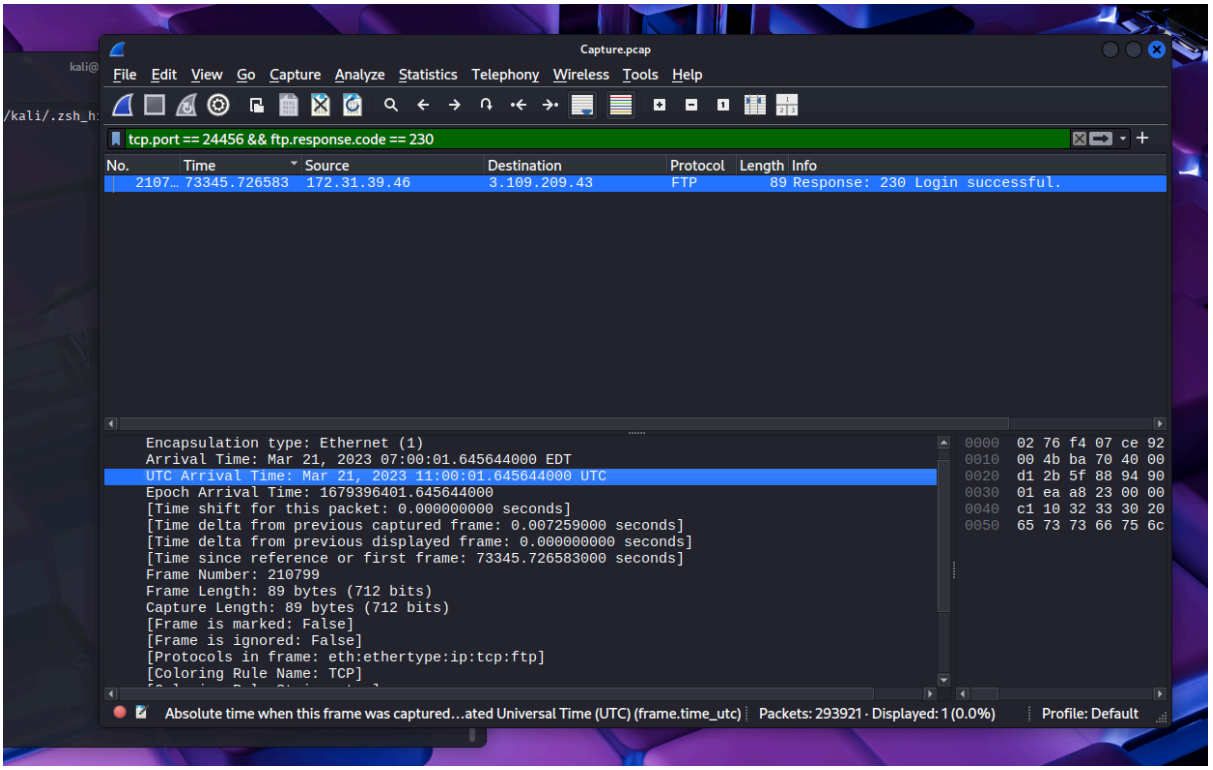


Traffic on TCP port 24456 appeared as plain TCP in Wireshark, because the program only knows FTP on port 21. I selected a packet on this port, opened Analyze → Decode As, added a new row with Field = TCP port, Value = 24456 and Current = FTP. After that the packets were shown as FTP and I could see the USER and PASS commands. I then used Follow → TCP Stream to read the full login.

Answer: abdullah.yasin : XhlhGame_90HJLDASxfd&hoooad

How does Decode As help with non-standard ports? Wireshark chooses the protocol decoder mostly by the port number. If a known service runs on a different port, Wireshark doesn't recognize it and shows only raw TCP. Decode As lets me manually tell Wireshark to treat that port as a given protocol, so the commands and response codes become readable. For this task I set TCP port 24456 to FTP.

TASK-13

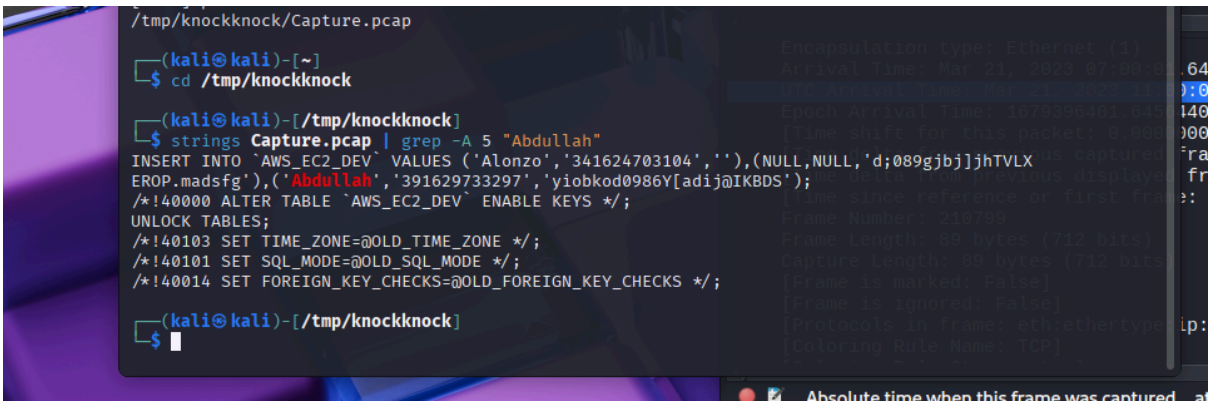


I filtered the traffic with `tcp.port == 24456 && ftp.response.code == 230`. Only one packet matches: frame 210799, the “230 Login successful” response sent by the server to 3.109.209.43. I ignored the 230 response on port 21, because that belongs to the earlier tony.shephard login. In Packet Details, under the Frame section, the UTC Arrival Time is Mar 21, 2023 11:00:01 UTC.

Answer: 2023-03-21 11:00:01 UTC

Where do I find the absolute time? In Packet Details, in the Frame section: Arrival Time (local), UTC Arrival Time and Epoch Arrival Time. I used the UTC line.

TASK-14

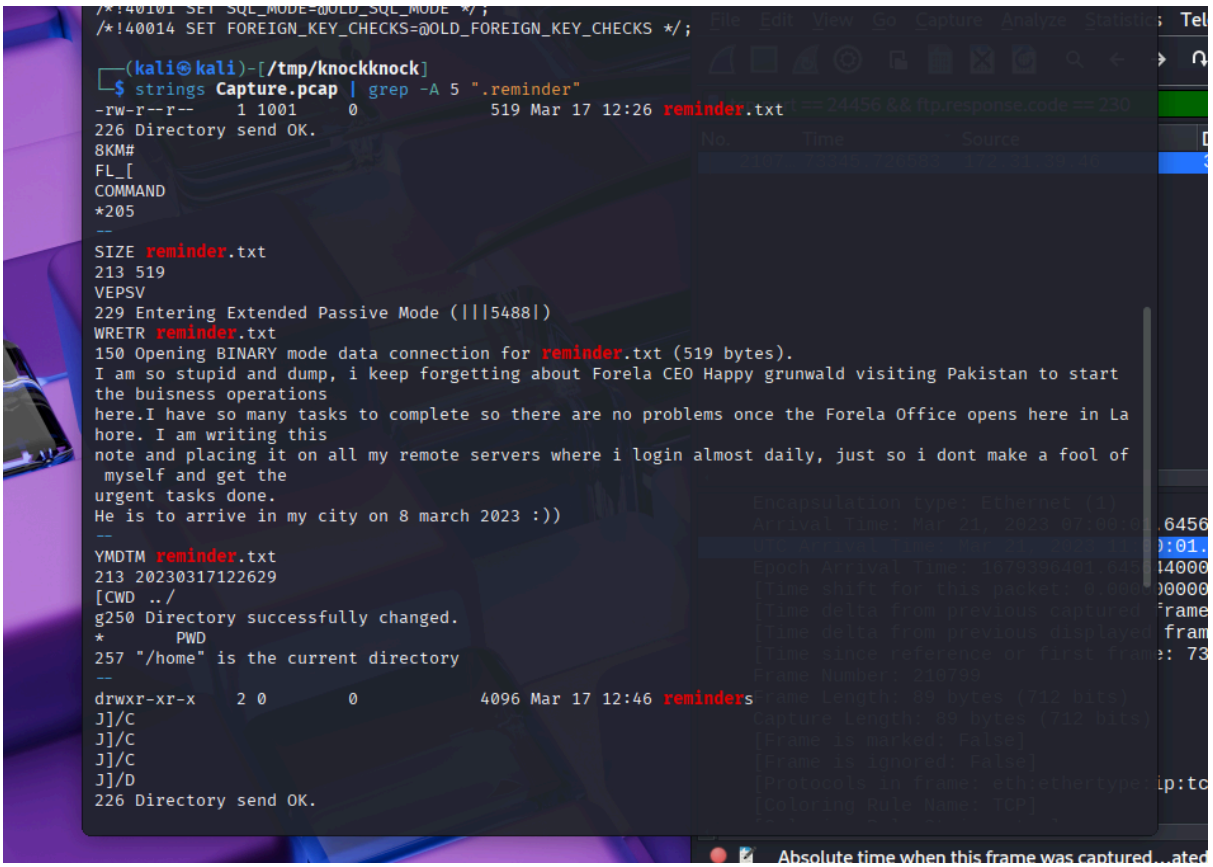


FTP sends data in plain text, so I searched the whole capture with *strings Capture.pcap | grep -A 5 "Abdullah"*. The output contains an SQL INSERT line for the table *AWS_EC2_DEV*, with Abdullah's account ID and password.

Answer: Account ID 391629733297, password yiobkod0986Y[adij@IKBDS

Risk compared to a local FTP account: An FTP account only gives access to one server. AWS credentials can give access to EC2 servers, S3 storage, databases, IAM and billing. The attacker could steal or delete data, run costly resources or create new access keys, so the damage can spread across the whole organisation

TASK-15

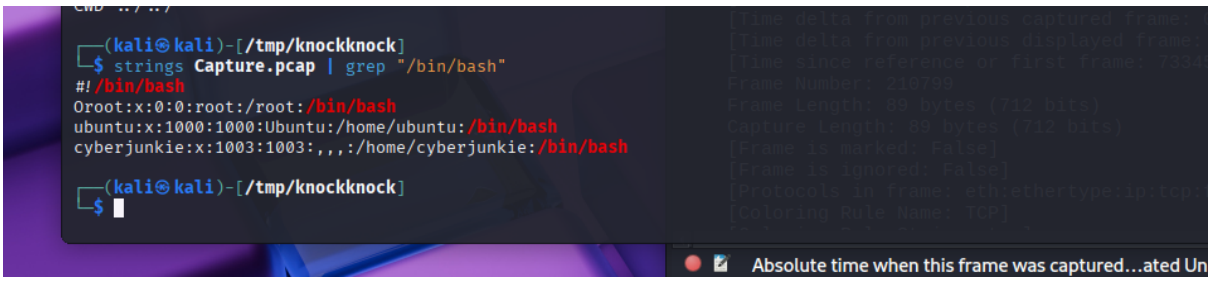


I ran *strings Capture.pcap | grep -A 5 ".reminder"*. The content of reminder.txt says the CEO will arrive in the author's city (Lahore) on 8 March 2023.

Answer: 8 March 2023

Risks of leaking travel schedules: Someone who knows where and when an executive will be can plan surveillance, theft or an attack. The information also helps with targeted phishing and social engineering, and it exposes business plans to competitors.

TASK-16

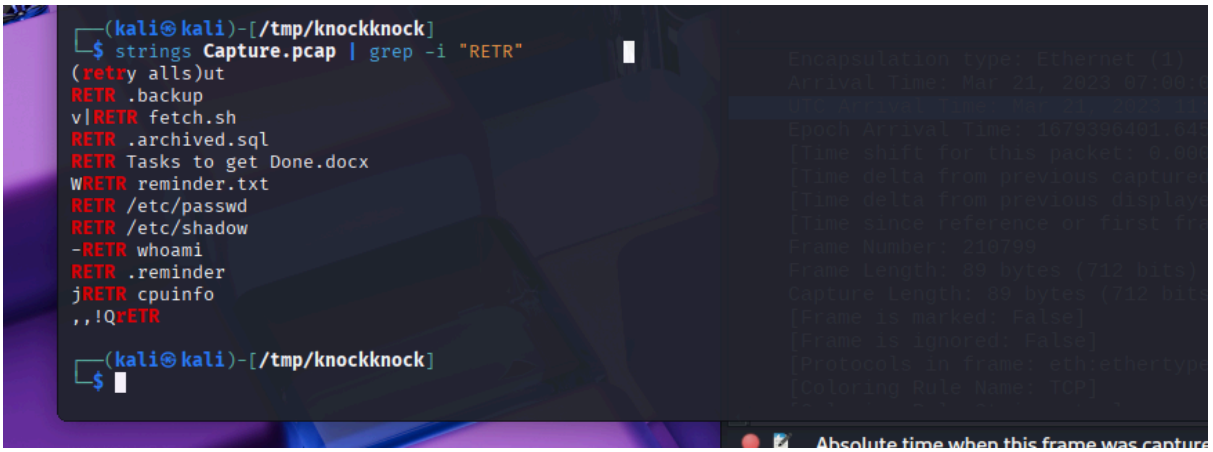


I ran *strings Capture.pcap | grep "/bin/bash"*. Besides root and the default ubuntu account, the output shows the user cyberjunkie with home directory /home/cyberjunkie and shell /bin/bash.

Answer: cyberjunkie

Why can a network leak threaten physical security? Two non-digital examples: a leaked travel schedule lets someone follow or ambush a person, and leaked names and office details help someone enter a building with a fake identity or steal access cards.

TASK-17

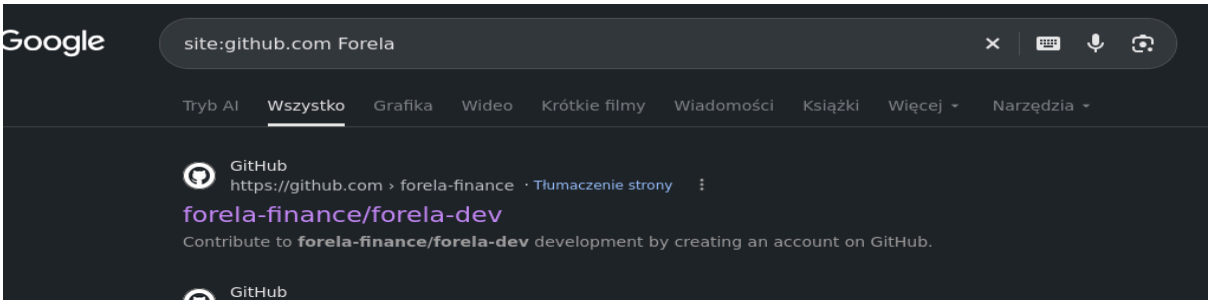


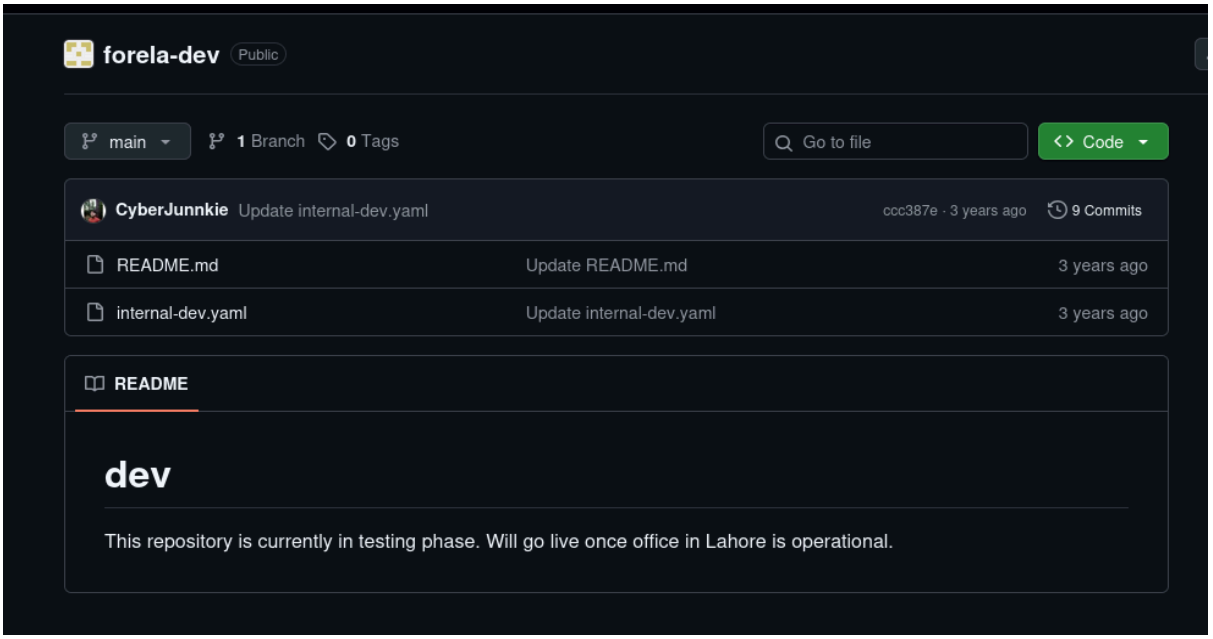
I ran *strings Capture.pcap | grep -i "RETR"* to list the files the attacker downloaded over FTP. Among them is *.reminder*. According to the task, the file was retrieved from the */opt/reminders* directory, so combining the directory and the file name gives the full path.

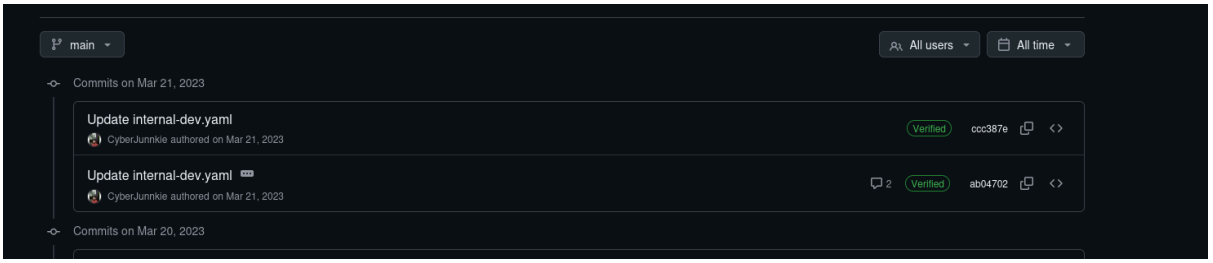
Answer: /opt/reminders/.reminder

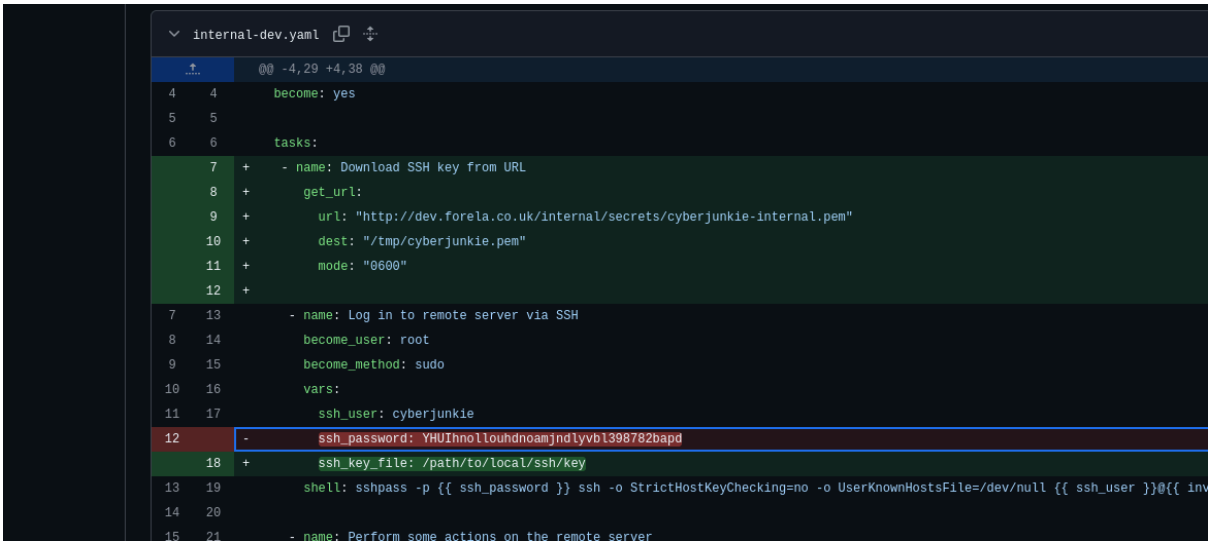
Was it visible or hidden? Hidden. In Linux, a file whose name starts with a dot is hidden and only shows with *ls -la*. The attacker had to list hidden files to find it.

TASK-18


Google
site:github.com Forela
Tryb AI
Wszystko
Grafika
Wideo
Krótkie filmy
Wiadomości
Książki
Więcej
Narzędzia
GitHub
https://github.com › forela-finance · Tłumaczenie strony
forela-finance/forela-dev
Contribute to forela-finance/forela-dev development by creating an account on GitHub.
GitHub


forela-dev
Public
main
1 Branch
0 Tags
Go to file
Code
CyberJunnkie Update internal-dev.yaml
ccc387e · 3 years ago
9 Commits
README.md
Update README.md
3 years ago
internal-dev.yaml
Update internal-dev.yaml
3 years ago
README
dev
This repository is currently in testing phase. Will go live once office in Lahore is operational.


main
All users
All time
Commits on Mar 21, 2023
Update internal-dev.yaml
CyberJunnkie authored on Mar 21, 2023
Verified
ccc387e
Update internal-dev.yaml
CyberJunnkie authored on Mar 21, 2023
2
Verified
ab04702
Commits on Mar 20, 2023

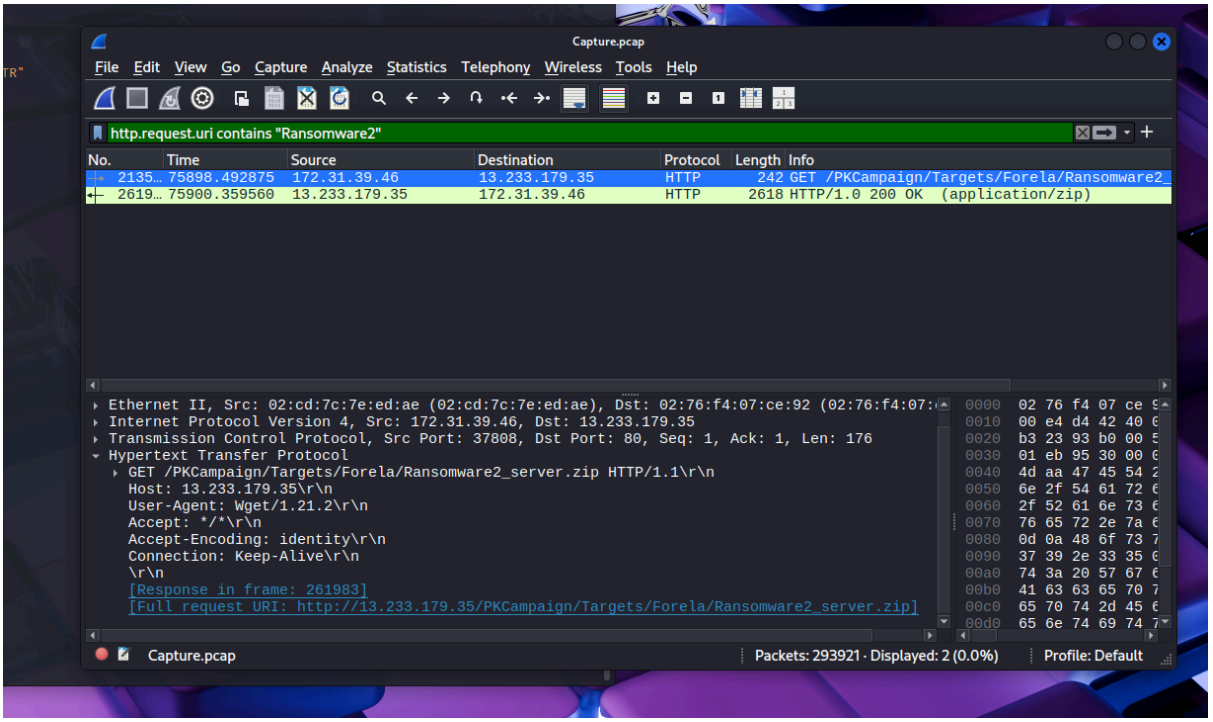


I searched `site:github.com Forela` and found the public repository forela-finance/forela-dev. In the commit history, the second “Update internal-dev.yaml” commit from 21 March 2023 shows a removed line with `ssh_password`. The developer replaced the hardcoded password with an SSH key file, but the old password stays visible in the history.

Answer: YHUIhnollouhdnoamjndlyvbl398782bapd

How does the Google Dork site:github.com Forela narrow search results, and why is it a primary OSINT technique? `site:github.com` limits the results to GitHub and the word “Forela” limits them to the target organisation. Developers sometimes commit passwords by mistake, and these stay in the commit history even after they are deleted. The technique uses only public information, so it is legal, passive and a common first step in OSINT.

TASK-19

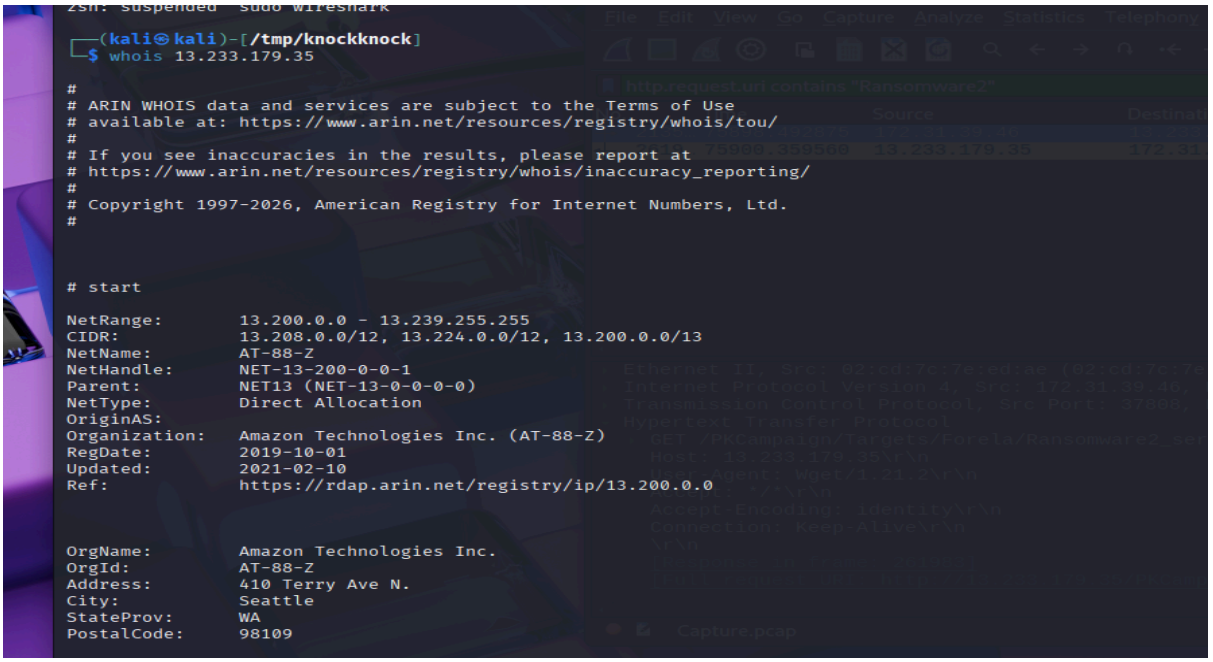


I applied the filter *http.request.uri contains "Ransomware2"* and found a single HTTP GET request. In Packet Details, the HTTP section shows *GET /PKCampaign/Targets/Forela/Ransomware2_server.zip with Host: 13.233.179.35*. Combining host and path gives the full URL.

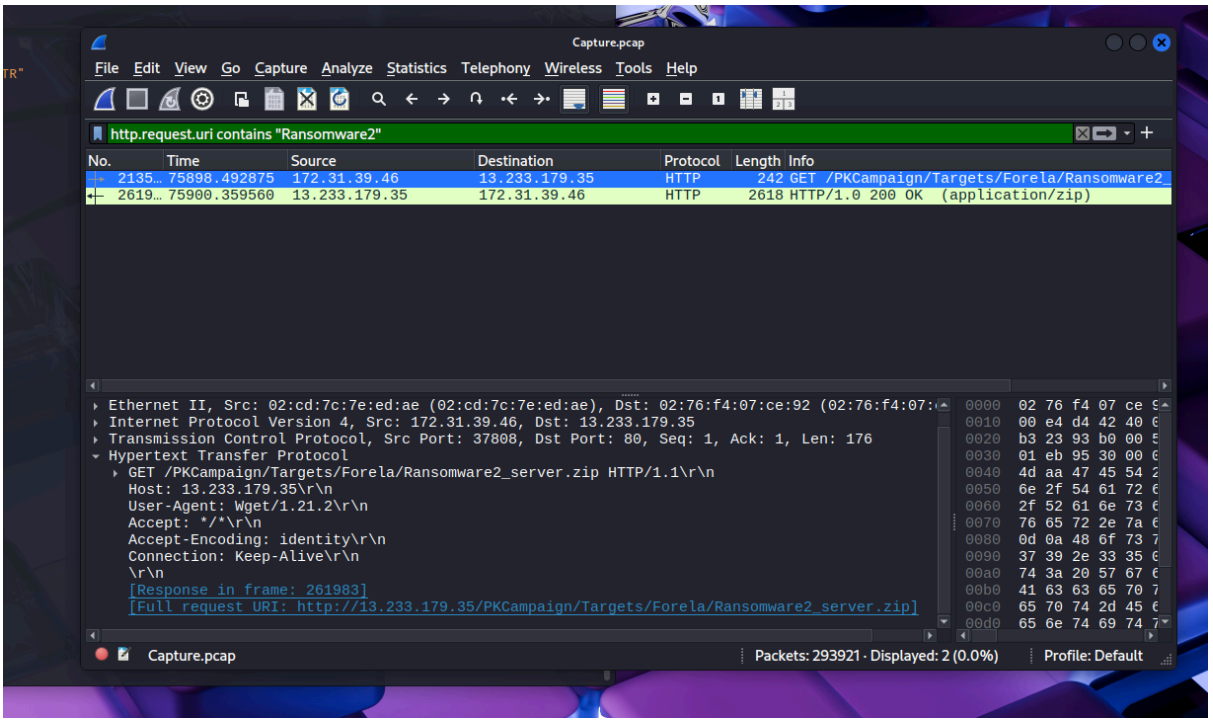
Answer:
hxxp://13[.]233[.]179[.]35/PKCampaign/Targets/Forela/Ransomware2_server.zip

Which IP address should be blocked as an IoC, and which cloud provider hosts it? *The IP 13.233.179.35 should be blocked on the firewalls. A whois lookup*

shows that the address belongs to Amazon (AWS)



TASK-20

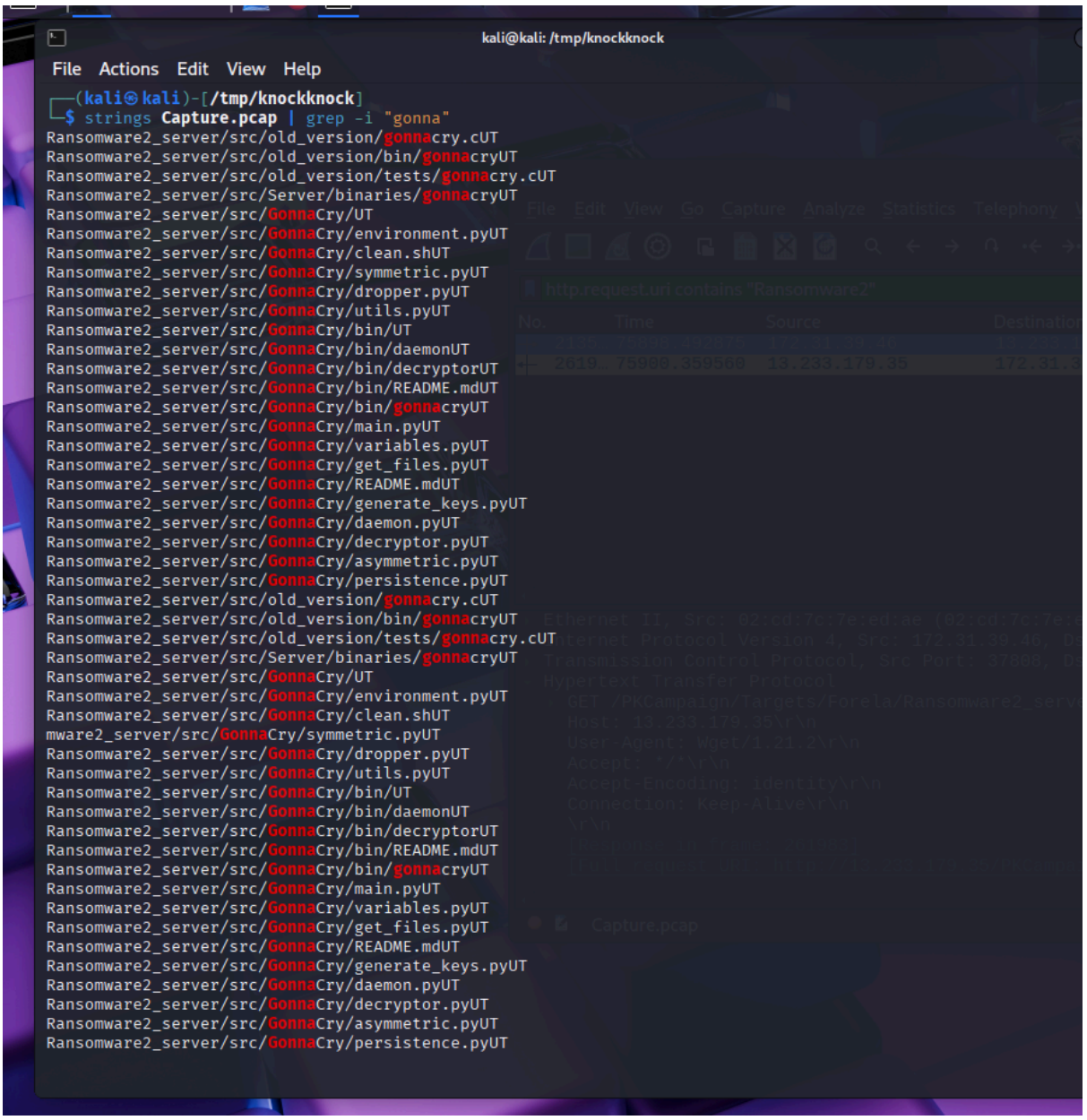


The same HTTP request contains the header *User-Agent: Wget/1.21.2*, so the attacker used the command-line tool Wget, version 1.21.2.

Answer: Wget 1.21.2

What does the User-Agent header represent, and how do SOC analysts use it? It tells the server which client sent the request. Browsers send a long string like *Mozilla/5.0 ...*, while command-line tools send their own names, such as Wget or curl. SOC analysts look for these tool names where only browser traffic is expected, which helps them separate normal user traffic from automated downloaders (LOLBins). The header can be faked, so it is a clue and not proof.

TASK-21



I searched the capture file directly with *`strings Capture.pcap | grep -i "gonna"`*. The file names inside the zip archive are visible in the transferred data and show the path *`Ransomware2_server/src/GonnaCry/...`*. The archive also contains files such as dropper.py, generate_keys.py, symmetric.py, asymmetric.py and decryptor.py, which match the typical structure of a ransomware (dropper, key generation, encryption and decryption routines). So the ransomware is called GonnaCry.

Answer: GonnaCry

The name is a reference to the WannaCry ransomware from 2017.